F11 从 0 做方案：后台治理、状态机、处罚与审计

> 管理后台最容易出现“接口藏起来就安全”“登录就是有权限”“UPDATE 成功就结束”等错误。F11 必须同时解决管理员授权、目标限制、状态转换、并发、审计和跨模块生效。

1. 1. 为什么要实现

论坛必须处理违规用户和内容：禁言、封禁、解除、角色调整、帖子审核/驳回/删除、置顶和精华。治理动作影响用户权利，因此必须留下谁在何时因为什么把什么状态改成什么状态。

2. 2. 从零会遇到的问题

1. **登录用户怎样证明是管理员？前端角色能信吗？**
   本项目回答： 拦截器先得到数据库当前角色，管理 Service 再执行 `AdminChecks.admin`；前端角色只用于界面展示，不能授权。
2. **管理员能否处罚自己、其他管理员或最后一个管理员？**
   本项目回答： 当前禁止处罚自己和其他管理员，并在角色变更时保留至少一名管理员，避免误操作锁死后台。
3. **用户状态允许怎样转换？**
   本项目回答： Service 用显式状态机限制转换；例如 BANNED 不能随意改成 MUTED，解除动作必须匹配当前状态。
4. **两个管理员同时审批怎样发现竞争？**
   本项目回答： UPDATE 条件带旧状态，只有第一个影响一行；第二个得到 0 行并返回 409，而不是覆盖结果。
5. **状态修改与审计只成功一半怎么办？**
   本项目回答： 状态、处罚记录与审计日志在同一个数据库事务，任一步失败全部回滚。
6. **禁言到期怎样解除，定时任务延迟怎么办？**
   本项目回答： 定时任务批量扫描，发帖/评论前又惰性检查并复用同一解除 Service；条件更新保证并发幂等。
7. **封禁后旧 JWT 和旧角色怎样失效？**
   本项目回答： 封禁递增 tokenVersion；拦截器每次查数据库状态与角色，所以旧 token 或旧 ADMIN 信息不能继续生效。
8. **动态更新置顶/精华会不会 SQL 注入？**
   本项目回答： 只允许后端枚举映射到固定字段/语句，值使用参数绑定，绝不把客户端字段名原样拼接。
9. **当前真的形成了先审后发流程吗？**
   本项目回答： 没有。F03 新帖默认 PUBLISHED，F11 的审核接口只是治理能力；完整审核流还需默认 PENDING、队列、通知和申诉。
10. **审计日志能否被修改、保存多久、谁能看？**
    本项目回答： 当前是普通追加表，应用层不提供修改入口，但数据库管理员仍可改；保留期、只读权限和防篡改存储尚未完成。
11. **ES 与缓存怎样跟随治理状态？**
    本项目回答： 数据库提交后尽力同步/失效，主事务不依赖外部系统；失败可能短暂展示旧状态，需要 Outbox、监控和重建。

3. 3. 三层授权模型

1. `AuthenticationInterceptor`：确认 token 有效，得到数据库当前角色。
2. `AdminChecks.admin`：Service 再确认 `role=ADMIN`。
3. 资源与状态检查：不能处罚自己/管理员，不能降级最后一名管理员，只允许合法状态转换。

前端隐藏管理菜单只改善体验，不是安全措施；Controller 路由受保护也不等于普通登录用户有管理权限。

4. 4. 状态与记录分开

- `user_account.status`：当前有效状态，便于登录/发帖快速判断。
- `user_punishment`：处罚和解除历史，包含操作人、原因、截止时间。
- `post.status`：`PENDING/PUBLISHED/REJECTED/DELETED` 当前内容状态。
- `admin_audit_log`：所有治理动作的 before/after、目标和原因。

当前状态放主表，历史放附表，兼顾快速判断和可追溯性。



5. 5. 技术选型与替代方案

部分	当前选择	为什么选	没选什么，为什么
授权	Service 显式角色检查	规则位置清楚，不能因内部调用绕过 Controller	只靠前端/路由不安全；AOP 简洁但对初学者隐藏执行链
权限模型	`USER/ADMIN` 二角色	当前功能简单	完整 RBAC/ACL 表更灵活，但没有多角色多资源需求前过重
状态规则	显式 switch/if 状态机	可读、容易返回具体错误	任意 UPDATE status 会产生非法转换；状态机框架当前没必要
并发	`WHERE id=? AND status=old` + affected rows	乐观检查，不长期占锁	悲观锁会降低并发；不带旧状态会静默覆盖他人操作
原子性	Spring 事务	状态、处罚、审计一起成功	审计异步写可能在故障时缺失关键记录
到期解除	定时扫描 + 请求时惰性检查	定时保证后台推进，发帖路径保证不会因任务延迟一直禁言	只定时会有延迟窗口；只惰性会让从不发帖的状态长期不清理

部分	当前选择	为什么选	没选什么，为什么
审计	追加表	查询和追责直接	仅普通日志可能轮转、格式不稳定；完整事件溯源对当前系统过重
搜索同步	提交后按 id 更新/删除 ES	主事务不受 ES 网络影响	事务内同步仍不能跨系统原子，并拉长事务

6. 6. 关键业务不变量

- 普通用户即使有合法 JWT，也不能调用任何管理 Service。
- 管理员不能处罚自己；当前实现也不允许处罚其他管理员。
- 至少保留一名管理员。
- 禁言截止时间必须晚于当前时间。
- 已封禁用户不再禁言；解除动作必须匹配当前状态。
- 只有 PENDING 帖子能 APPROVE/REJECT；已删除帖子不能再操作。
- 只有 PUBLISHED 帖子能置顶/精华。
- 每次治理必须给 1-500 字原因。
- 条件 UPDATE 影响 0 行表示状态已被别人改过，返回 409，而不是假装成功。

7. 7. 禁言到期为什么有两条路径

`PunishmentService.expireDueMutes` 每分钟最多扫 100 人；`PostingPermission.requireCanPost` 在用户发帖/评论前也检查最新处罚，发现到期便调用同一个 `expireUserIfDue`。

共享 Service 很重要：不能在发帖检查里裸 `UPDATE NORMAL`，否则没有解除处罚历史和系统审计。条件更新只让一个并发请求真正解除，其他请求看到状态已恢复。

8. 8. token 与状态怎样联动

- 封禁时 `setUserStatus(... revokeToken=true)` 递增 tokenVersion，旧 token 失效。
- 拦截器每次从数据库读取当前 role，因此角色改变立即影响 `CurrentUserDTO`，不会只信 JWT 里的旧 role。
- 禁言用户仍可登录和浏览，只在 `PostingPermission` 阻止发帖/评论；这是产品定义，不等同封禁。

9. 9. 缺陷台账

缺陷/后果	状态	结论
F03 新帖默认 PUBLISHED	**审核流程缺口**	F11 有审核接口但不是完整默认待审；若要先审，创建状态必须改 PENDING

缺陷/后果	状态	结论
只有 USER/ADMIN 两角色	**当前可接受**	版主、运营、只读审计员出现后再做 RBAC 权限表
没有管理员 MFA/二次确认	**未解决**	高风险操作上线前应加 MFA、短期再认证和敏感动作确认
审计表仍可被数据库管理员修改	**未解决**	可做追加权限、远程审计、哈希链/WORM 存储和备份
定时任务多实例会同时扫描	**效果已由条件更新幂等**	会有重复扫描开销；规模大可任务分片/调度锁
每轮最多 100 人，积压时解除延迟	**可恢复**	下轮继续且发帖时惰性解除；需监控积压并调批量/频率
ES afterCommit 失败导致已删内容仍可搜	**可重建未完全解决**	生产使用 Outbox/MQ 并监控同步延迟
审计没有 IP、User-Agent、requestId	**未解决**	生产调查需要请求上下文和链路 id
没有申诉/恢复内容流程	**产品暂留**	当前只做管理动作；申诉需要新状态和权限边界
`operator_id=0` 表示系统任务	**简化约定**	数据库外键和展示要识别系统主体，生产可建专门 system principal

10. 10. 为什么显式 Service 校验而不是全放 AOP

AOP 适合稳定的"必须是管理员"横切规则，但具体状态转换、不能处罚自己、最后管理员、帖子状态等需要加载业务数据。把这些藏在多个切面会让执行顺序难看懂，也容易出现内部调用绕过。当前把主要授权和状态机放 Service，牺牲少量重复换可审计性。

11. 11. 面试追问

问：登录鉴权通过为什么还要 Service 权限？ 认证只证明"你是谁"，授权才判断"能做什么"。普通用户也能登录，但不能治理别人。

问：两个管理员同时审批如何处理？ 两人都可能读到 PENDING，UPDATE 带旧状态；只有一个影响 1 行，另一个得到 0 行并返回 409 刷新。

问：为什么审计必须同事务？ 状态改变但审计失败会失去追责信息；审计成功而状态回滚也会记假操作。同库事务把二者绑定。

问：定时任务晚一分钟，用户会多禁言一分钟吗？ 发帖路径还会惰性检查截止时间并复用解除 Service，所以关键权限不完全依赖调度及时性。

问：有审核接口就算完成内容审核流吗？ 不算。当前创建默认发布；完整先审需要创建为 PENDING、公开查询过滤、管理员队列、结果通知和申诉策略。

11.1 11.1 面试官还能怎样继续追问

延伸：RBAC、ACL、ABAC 有什么区别？ RBAC 按角色授权，ACL 对具体资源列主体权限，ABAC 根据用户/资源/环境属性决策。当前 USER/ADMIN 是最小 RBAC，版主分区管理出现后才需要更细模型。

延伸：审计怎样防篡改？ 应限制应用账号只有 INSERT、把日志异步复制到独立账号/系统，可加入前一条哈希形成链并写 WORM 存储；但哈希链也需要安全锚点和密钥管理。

延伸：多实例定时任务为什么可能重复？ 每台实例都会触发扫描；本项目靠条件 UPDATE 使业务效果幂等，但仍有重复查询。可用 ShedLock/Quartz 集群/任务分片减少重复，不能只加本地 synchronized。

延伸：高风险管理操作还可怎样保护？ MFA、短期再认证、双人审批、操作原因、requestId/IP/User-Agent 审计、速率限制和异常告警，必要时提供回滚/申诉流程。

12. 12. 源码与验证

- 用户治理：`AdminUserController → AdminUserServiceImpl → Admin/Punishment/AuditLogMapper`。
- 帖子治理：`AdminPostController → AdminPostServiceImpl → Admin/AuditLogMapper`。
- 共用检查：`AdminChecks`、`PostingPermission`、`PunishmentServiceImpl`。
- 表：`user_account`、`user_punishment`、`post`、`admin_audit_log`。
- 测试：`FeatureFlowApiTest.messagesAndAdminChecks`、`expiredMuteWritesAuditBeforePosting`。

13. 13. 学习完成检查（先回答，再点击展开）

▶ 自测 1：认证、授权和资源状态检查分别解决什么？

参考回答： 认证确认调用者是谁；管理员授权判断该身份能否进入治理功能；资源检查处理不能处罚自己/管理员、最后管理员和合法状态转换。三层缺一都会留下越权或非法状态。

▶ 自测 2：两个管理员同时审批 PENDING 帖子时怎样避免覆盖？

参考回答： 两者都可读到旧状态，但 UPDATE 带 id + oldStatus=PENDING；第一个成功后第二个影响 0 行并返回 409，提示刷新。这是乐观并发控制。

▶ 自测 3：为什么处罚状态与审计必须同事务？

参考回答： 状态成功而审计失败会失去追责，审计成功而状态回滚会记录虚假动作；同库事务使两者一起提交或回滚。跨系统远程审计则还需 Outbox。

▶ 自测 4：为什么当前不能声称已经实现完整内容审核平台？

参考回答： 新帖仍默认 PUBLISHED，缺少默认待审、审核队列、结果通知、申诉和 SLA；当前实现的是管理状态转换和审计骨架，不是完整产品流程。